

La Arquitectura de la Defensa

Fundamentos de Ciberseguridad: Riesgo, Amenazas y Auditorías Técnicas

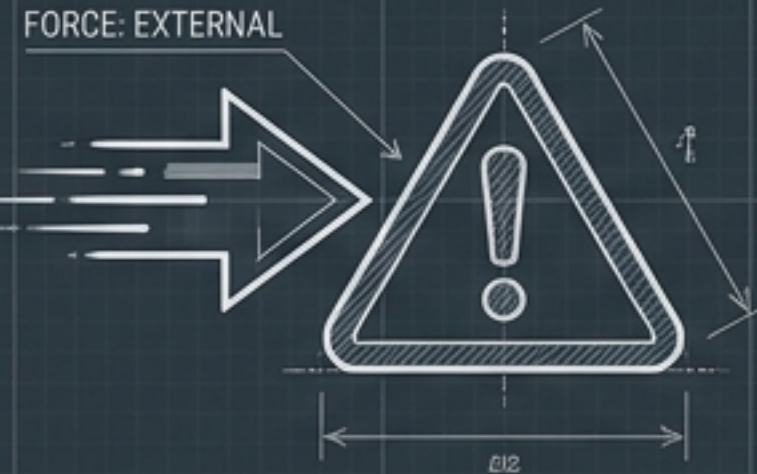
Presentado por Carlos Noboa



Vulnerabilidad

Debilidad o **fallo** en un sistema de información que pone en **riesgo** la seguridad de la información.

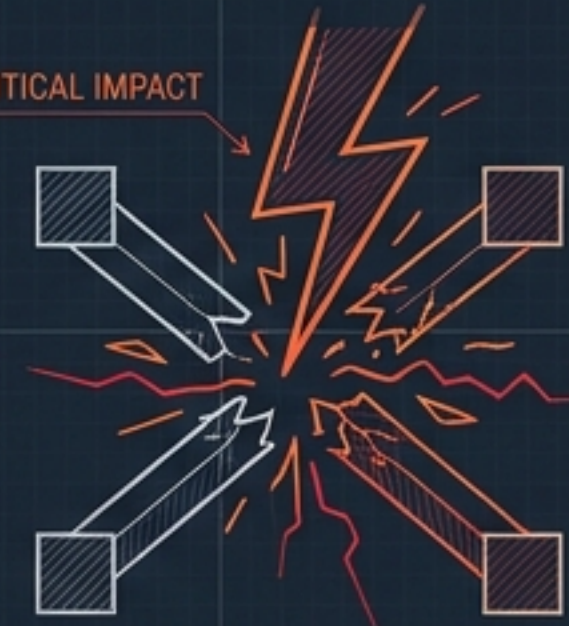
FORCE: EXTERNAL



Amenaza

Toda **acción** que **aprovecha** una vulnerabilidad para **atentar** contra la seguridad de un sistema de información.

CRITICAL IMPACT



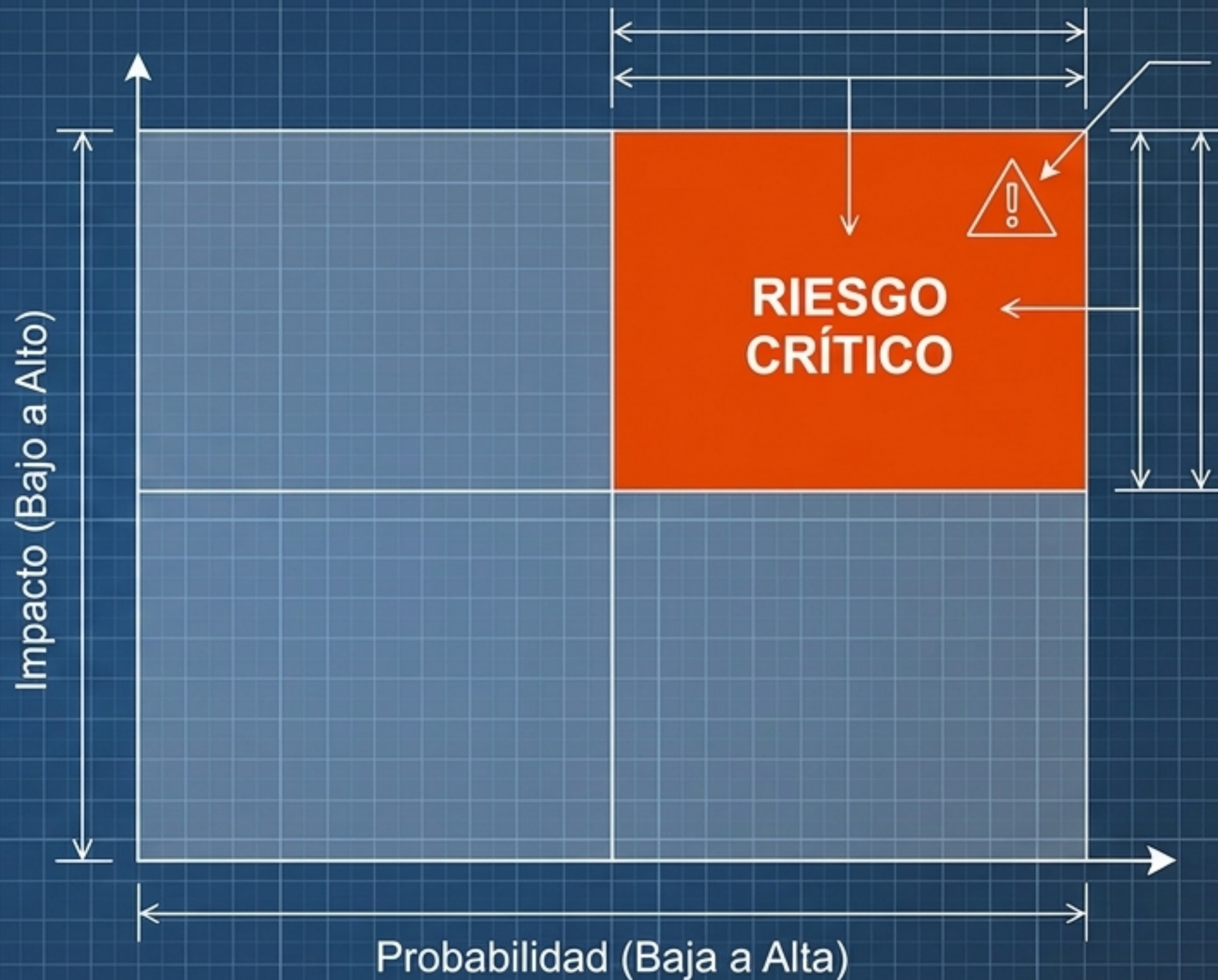
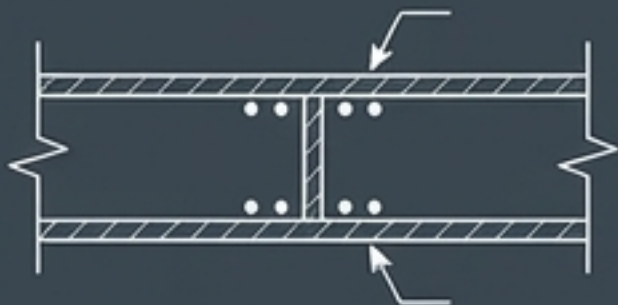
Riesgo

La **posibilidad** de que se produzca un **incidente** de seguridad, materializándose una **amenaza** y causando **pérdidas** o **daños**.



El riesgo solo existe donde una amenaza se cruza con una vulnerabilidad dentro de un sistema. Se mide asumiendo que existe una cierta vulnerabilidad frente a una determinada amenaza.

No todos los riesgos son iguales.
La relación entre probabilidad e impacto permite priorizar la remediación.

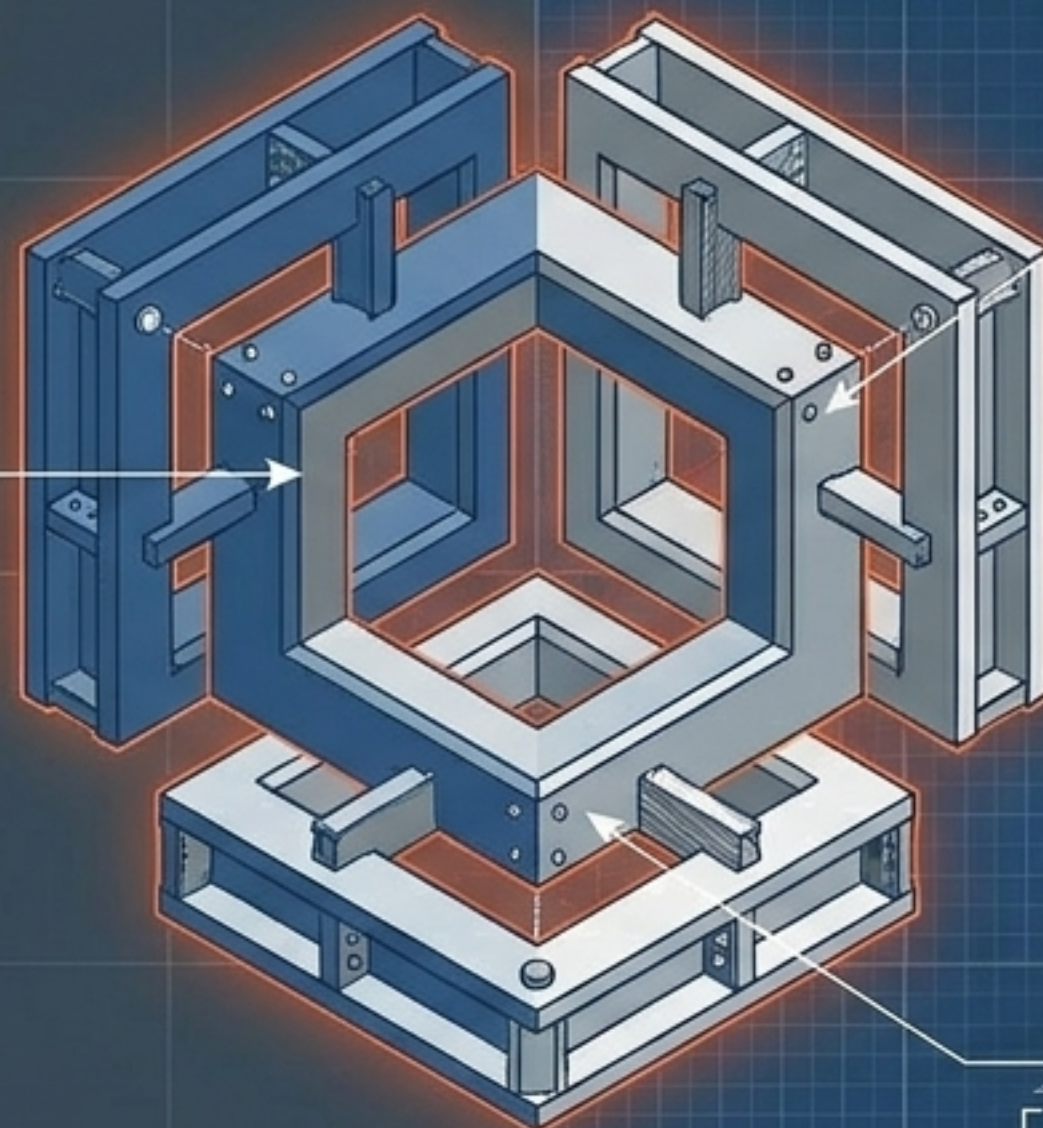


Las vulnerabilidades con mayor riesgo suelen ser fáciles de explotar de forma remota, no requieren autenticación y permiten tomar el control total del activo vulnerable.

El Objetivo de Protección: Los Datos

Confidencialidad

Proteger la información de accesos ilegítimos o filtraciones.



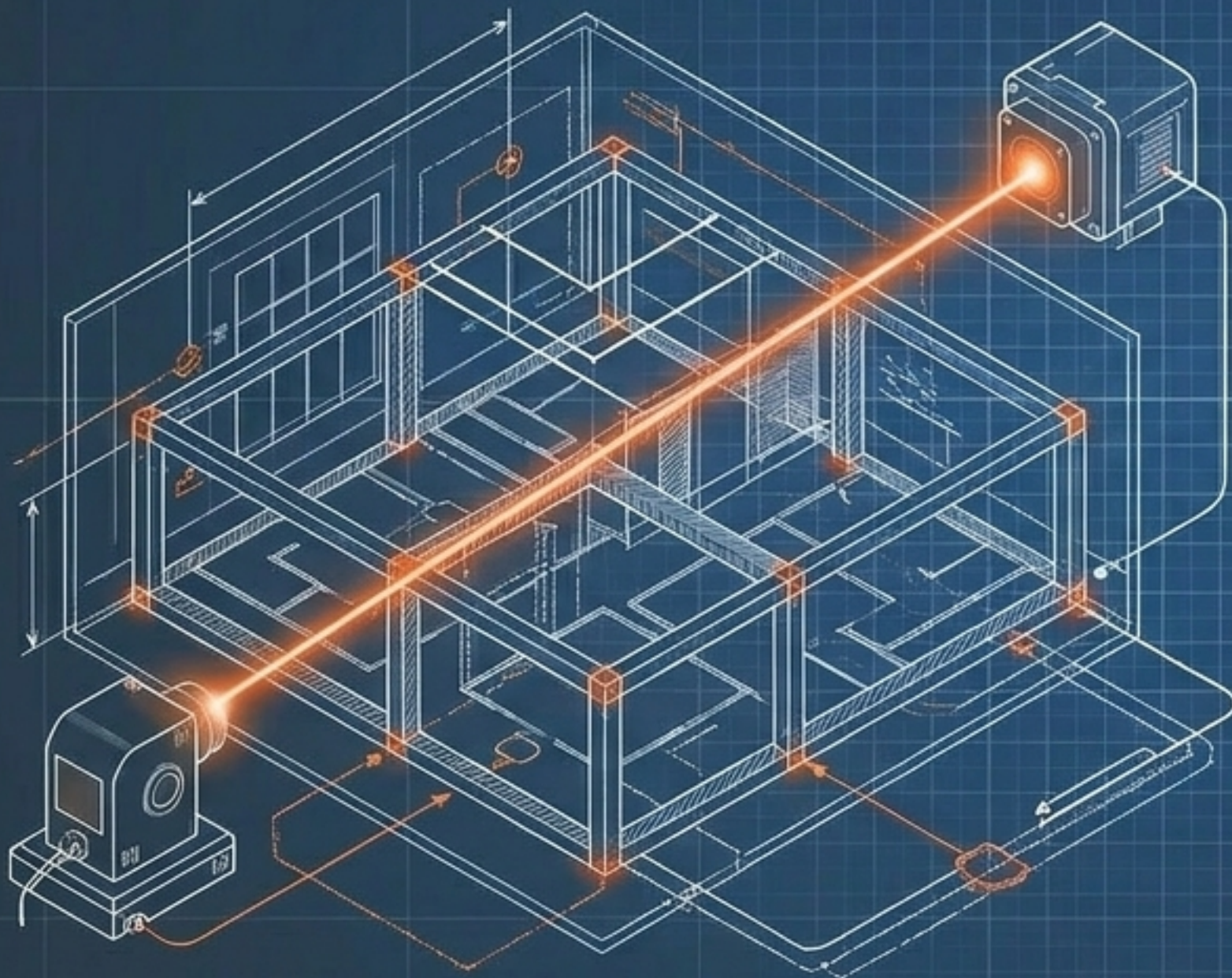
Integridad

Proteger la información de modificaciones ilegítimas.

Disponibilidad

Garantizar el acceso y uso de la información y los sistemas.

El Test de Intrusión (Pentest)



Identificar todas las vulnerabilidades de un sistema informático, tomando como principal amenaza a hackers no éticos.

Identificar Vulnerabilidad

Calcular Riesgo

Proponer Recomendación de Mitigación

Nota Crítica: Es imprescindible contemplar el contexto de la empresa a la hora de categorizar el riesgo.

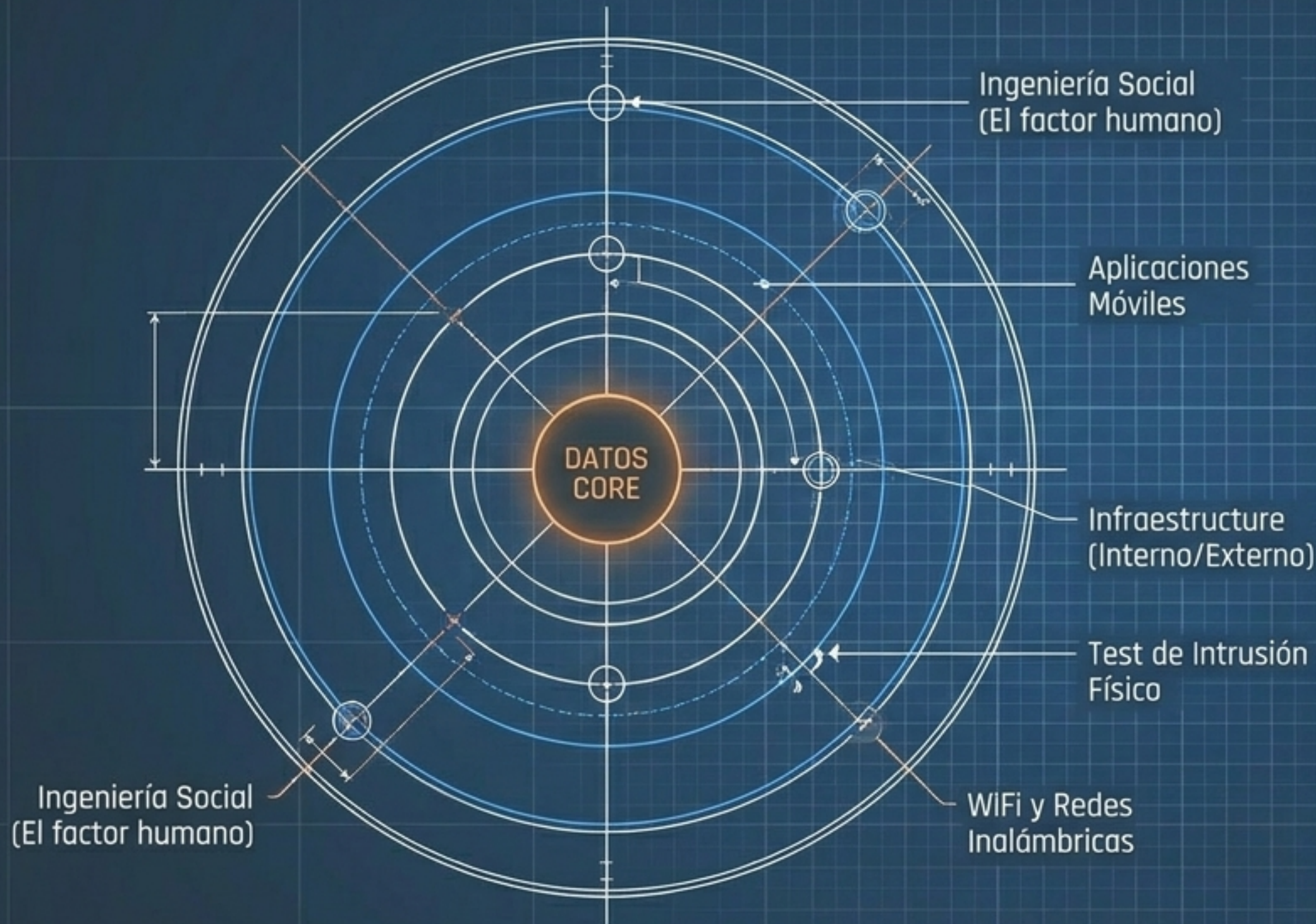
Estandarización del Riesgo: CVSS

Common Vulnerability Scoring System



El método más común a nivel mundial para calcular de forma estructurada el riesgo técnico de una vulnerabilidad.

Tipos de Pentest: El Perímetro de Auditoría



Cada tipo de revisión ofrece una visión diferente.

Dependiendo de las necesidades y la madurez en ciberseguridad de la empresa, interesará realizar un tipo u otro.

El Principio de Realidad

“Realizar un pentest no garantiza nunca al 100% que un sistema sea seguro.”

Es una medida preventiva fundamental para escenarios donde se sospecha de riesgos no identificados. La revisión de la ciberseguridad es una tarea continua para cualquier entidad con información digitalizada.